HANTECH CAPSTONE PROJECT 138

From Vulnerability to Compliance: Securing Legacy and Cloud Systems

Integrated final report — 9 November 2026
Authorised target: Metasploitable 2 — 192.168.138.20
Assessment source: Kali Linux — 192.168.138.10
Network: CAPSTONE138_ISOLATED (VirtualBox Internal Network)
Status: Integrated final draft; limitations are explicit

Team allocation

The following names are reproduced from the project task-allocation record. They are allocation labels; this report does not fabricate signatures, independent reviews or personal attestations.

Assigned name	Allocated task	Workstream represented
Jeffrey	Tasks 1 & 2	Lab environment, scope, discovery and service inventory
Bonaventure	Tasks 3 & 8	Vulnerability research, executive summary, final report and presentation
Abundance	Task 4	Risk assessment
Adeayo	Task 5	Security controls and recommendations
Amos Talks	Task 6	GRC policies
No named assignee in recorded allocation	Task 7	Desk-based cloud baseline completed; live tenant assessment not possible without scope

No instructor role or instructor approval is assumed. The assignment theme refers to a second system, but the available authorised scope identifies only Metasploitable 2. No substitute target was invented or scanned.

1. Executive summary

This project examines the security implications of legacy network services and application configurations, then translates the observed weaknesses into risk, technical safeguards, governance requirements and a cloud-security baseline for the HanTech case study.

The assessment was conducted in an isolated VirtualBox environment. Kali Linux (192.168.138.10) was used as the assessment source and Metasploitable 2 (192.168.138.20) as the only expressly authorised target. The guests communicated over the VirtualBox Internal Network CAPSTONE138_ISOLATED. The host was not attached to that isolated network.

A full TCP connect/version-light discovery scan covered ports 1–65535 and identified 30 open and 65,505 closed TCP ports. A targeted TCP recheck independently reconfirmed seven selected additional ports. A separate UDP top-100 scan identified four confirmed open responses, three open|filtered/no-response results and 93 closed ports. The UDP scan was limited to the top 100 ports and is not a full UDP-port scan.

Five priority findings were selected because their configuration or exposure conditions were directly supported by saved evidence:

1. NFS exports the root filesystem to wildcard clients with read/write access and root squashing disabled.
2. SMB permits anonymous share enumeration and directory metadata listing.
3. A Mutillidae database-configuration resource is reachable over HTTP and returned HTTP 200 with a text/plain content type.
4. The public HTTP landing page displays a default lab credential pair.
5. Telnet and Berkeley r-services listeners are bound to all IPv4 interfaces.

The provisional contextual risk scores are 20 (Critical), 8 (Moderate), 16 (High), 16 (High) and 12 (High). These are qualitative likelihood-times-impact estimates for the observed lab conditions. They are not CVSS scores or a risk acceptance for HanTech production.

The assessment did not exploit the target, submit credentials, mount NFS, read SMB file contents, retrieve the Mutillidae configuration response body, query a database or change target configuration. Accordingly, the report distinguishes observed exposure from potential impact. Samba CVE-2007-2447 remains a separate high-confidence applicability candidate, but exact installed-binary patch provenance is unresolved; it is not represented as a confirmed exploited vulnerability. Other service/version leads are not promoted to CVEs without build, patch and prerequisite evidence.

The report includes technical remediation recommendations, a preventive/detective/corrective control matrix, five draft GRC policies, conditional legal/framework applicability, and a cloud shared-responsibility baseline. No cloud provider, tenant, account, subscription, region or authorised cloud identity was supplied. Task 7 is therefore completed as a desk-based baseline only; no live cloud assessment is claimed.

Conclusion: The designated HanTech capstone assessment environment contains serious legacy configuration and exposure weaknesses. These findings are attributed to the isolated Metasploitable 2 virtual environment assessed for this project. They do not independently establish the condition of a separate HanTech production network; production applicability requires separate asset, configuration, data-flow and compensating-control evidence.

2. Objectives

- Establish and document an isolated lab environment.
- Identify the authorised target's reachable TCP and UDP services within the defined scan scope.
- Review selected services and configurations using non-invasive methods.
- Select five priority, evidence-backed security findings.
- Assess risk using a consistent qualitative model.
- Recommend preventive, detective and corrective controls.
- Develop a GRC policy register with conditional legal and standards mapping.
- Produce a cloud-security baseline and identify evidence needed for a future live assessment.
- Preserve native outputs, screenshots, execution receipts and integrity hashes.

3. Scope, authorisation and rules of engagement

3.1 Authorised technical scope

Item	Value
Assessment source	Kali Linux, 192.168.138.10/24
Target	Metasploitable 2, 192.168.138.20/24
Virtual network	VirtualBox Internal Network, CAPSTONE138_ISOLATED
Target MAC	08:00:27:f8:7d:a3
Kali MAC	08:00:27:32:09:84
Host access	Local VM console management; host not attached to lab network

The lab uses an isolated internal network, not a VirtualBox host-only network. The second system mentioned in the broad assignment theme was not identified as an authorised target in the available scope record. No scan was run against Dev Guru or another unapproved system.

3.2 Permitted and excluded activity

Permitted activity included host/service discovery, read-only configuration review, benign HTTP HEAD requests, non-invasive service enumeration, public vendor-advisory research and evidence capture.

Not performed: exploitation, brute force, password spraying, credential submission, NFS mounting, remote file writes/deletes, upload operations, state-changing HTTP methods, database access, destructive tests, external-system testing or cloud-tenant probing.

3.3 Reporting boundary

Metasploitable 2 is the designated HanTech assessment environment for this capstone, implemented as an isolated, deliberately vulnerable virtual appliance. Findings establish conditions observed in that assessment environment. They do not independently establish the state of any separate HanTech production system. Production applicability requires separate written authorisation and actual asset/configuration evidence.

4. Methodology and evidence handling

The workflow was: verify topology and reachability; conduct full TCP discovery; perform targeted TCP corroboration; conduct UDP top-100 discovery; review selected local configurations and limited remote read-only responses; map observations to findings; reconcile findings and risks; develop control/GRC/cloud recommendations; refresh the evidence manifest.

Evidence records include timestamps, source/target details, command context, outputs, screenshots, receipts and SHA-256 hashes. The manifest demonstrates file integrity relative to recorded hashes; it does not independently prove every technical interpretation or remediation.

5. Lab environment

Kali and Metasploitable 2 were configured on VirtualBox Internal Network CAPSTONE138_ISOLATED. Guest addresses were 192.168.138.10/24 and 192.168.138.20/24. The host was not attached to the isolated network. Network readiness and bidirectional guest reachability are recorded in the lab evidence packet. No routing or forwarding was enabled to expose the target.

6. System and service discovery

6.1 Full TCP scan

Nmap 7.98 completed a TCP connect/version-light scan of ports 1–65535 on 8 November 2026.

Metric	Result
TCP ports scanned	65,535
Open	30
Closed	65,505
Runtime	66.72 seconds
Native outputs	.nmap, .gnmap and .xml preserved

6.2 Targeted TCP corroboration

On 9 November 2026, a selected-port recheck reconfirmed seven additional ports absent from the earlier top-1,000 baseline.

Port	Observed identification	Interpretation
3632/TCP	distccd v1 / GNU 4.2.4	Service identified; no protocol interaction or exploit test
6697/TCP	UnrealIRCd	Listener confirmed; exact version and binary provenance unresolved
8787/TCP	Ruby DRb RMI / Ruby 1.8	Service identified; no RMI interaction
33543/TCP	Unknown	Open; service not identified
47335/TCP	Unknown	Open; service not identified

47852/TCP	Unknown	Open; service not identified
60679/TCP	Unknown	Open; service not identified

All seven selected ports were confirmed open in the targeted recheck. Discovery does not itself prove vulnerability.

6.3 UDP top-100 scan

Port	State	Identification	Interpretation
53/UDP	Open	ISC BIND 9.4.2	Confirmed response
111/UDP	Open	rpcbind	Confirmed response
137/UDP	Open	NetBIOS Name Service	Confirmed response; no OS inference
2049/UDP	Open	Nmap label rpcbind	Confirmed response; NFS application/version not established by this probe
68/UDP	open	filtered	DHCP client label
69/UDP	open	filtered	TFTP label
138/UDP	open	filtered	NetBIOS Datagram label

The scan reported 93 closed ports and a retransmission-cap warning. The three open|filtered results are not counted as confirmed open. This was not a full UDP-port scan.

6.4 Service inventory

The machine-readable service inventory contains 30 TCP records and seven UDP observations, with zero duplicate protocol/port keys. It is retained at 03_System_Discovery\SERVICE_INVENTORY.csv.

7. Vulnerability assessment — five priority findings

F-01 — Wildcard writable NFS root export with root squashing disabled

Severity: Critical (provisional contextual risk)
Classification: Confirmed configuration weakness
Affected service: NFS/RPC, TCP 111 and 2049; related UDP responses on 111 and 2049.

Evidence: Read-only review recorded the export / *(rw,sync,no_root_squash,no_subtree_check). showmount, rpcinfo and local exports configuration were used as supporting evidence.

Security significance: A root filesystem export to wildcard clients with read/write access and root squashing disabled can expose the host filesystem to a client accepted by the export rule.

Potential impact: Depending on reachability and client acceptance, an untrusted client could potentially obtain excessive filesystem access or alter data. This impact was not demonstrated.

Limitations: No remote NFS mount, file read/write, privilege change or filesystem modification was attempted.

Recommendation: Remove the root filesystem export. Export only necessary data paths, restrict access to explicit trusted clients, use read-only exports where possible, enforce root squashing and restrict RPC/NFS at the network boundary. Validate through approved configuration review and a safe post-change export check.

F-02 — Anonymous SMB share enumeration and directory metadata disclosure

Severity: Moderate (provisional contextual risk)
Classification: Confirmed anonymous-access exposure
Affected service: SMB over TCP 139 and 445.

Evidence: Anonymous SMB share enumeration succeeded and an anonymous listing of the tmp directory returned metadata.

Security significance: Anonymous enumeration reveals share names and directory metadata to unauthenticated users and may disclose internal naming or operational information.

Potential impact: Further access depends on share ACLs and file permissions. File-content access and write access were not tested.

Recommendation: Disable guest/null-session enumeration unless documented as required. Apply per-share least-privilege ACLs, remove unused shares, segment SMB and monitor anonymous access attempts. Verify denial using an authorised non-destructive retest.

F-03 — Mutillidae configuration resource reachable over HTTP

Severity: High (provisional contextual risk)
Classification: Confirmed remote resource exposure
Affected service: HTTP over TCP 80.

Evidence: An independent Kali HTTP HEAD request returned HTTP 200, content type text/plain and response length 177 bytes for the configuration resource. The genuine screenshot and review receipt are retained.

Security significance: A configuration resource within a web-accessible path may expose database settings or other sensitive configuration information. The remote response confirms resource reachability, not secret disclosure.

Potential impact: If a GET response contains usable secrets, the exposure could support unauthorised application or database access. The body and secret values were deliberately not retrieved.

Limitations: No GET body, secret value, credential validity, database privilege or database access was obtained or tested.

Recommendation: Remove configuration resources from the document root, deny direct web access to sensitive paths/extensions, store secrets in a managed secret store or protected configuration location, apply restrictive filesystem permissions, review access logs and rotate credentials if a secret is later confirmed exposed through an authorised process.

F-04 — Default lab credential pair displayed on public HTTP landing page

Severity: High (provisional contextual risk)
Classification: Confirmed public information disclosure
Affected service: HTTP over TCP 80.

Evidence: The unauthenticated HTTP landing page visibly displayed a default lab credential pair. The report intentionally does not reproduce the credential string.

Security significance: Publishing default credentials discloses an authentication path to any party able to reach the page. Risk is heightened if the account remains enabled or is reused.

Potential impact: Account access is possible only if the credentials remain valid for an accessible service. Validity, privileges and cross-service reuse were not tested.

Recommendation: Remove credential material from public content, disable or rotate default accounts through approved change control, use unique managed secrets, enforce MFA for privileged access where supported and scan public web content/repositories for credential disclosures.

F-05 — Telnet and Berkeley r-services listening on all IPv4 interfaces

Severity: High (provisional contextual risk)
Classification: Confirmed insecure remote-service exposure
Affected services: TCP 23, 512, 513 and 514.

Evidence: Telnet and Berkeley r-services listeners were identified on 0.0.0.0, and corresponding inetd service definitions were reviewed.

Security significance: Telnet and legacy r-services provide outdated remote administration mechanisms and may expose credentials or trust-based access paths.

Potential impact: Authentication, trust relationships and command-access consequences remain untested.

Limitations: No login, trust evaluation, network interception or remote command execution was attempted. Root trust-file contents were not retrieved.

Recommendation: Disable Telnet, rexec, rlogin and rsh where not explicitly required. Replace necessary administration with supported SSH, strong authentication, MFA for privileged access, source restrictions and centralised session logging. Confirm closure through an approved listener inventory and configuration evidence.

8. Additional vulnerability and service leads

These items are not counted as additional confirmed CVEs:

- **Samba CVE-2007-2447:** Samba 3.0.20 and an active username-map script setting indicate that upstream prerequisites may be present. Exact installed-binary patch provenance is unresolved. No trigger or exploit was sent. Report only as a high-confidence applicability candidate, not confirmed exploitation.
- **Unsupported Apache/PHP:** Legacy package versions are confirmed, but Ubuntu package backports and exact advisory prerequisites must be considered. No specific Apache or PHP CVE is asserted from version strings alone.
- **UnrealIRCd:** Listener/process evidence exists, but exact version and binary provenance for CVE-2010-2075 are unresolved. No trigger was sent.
- **vsftpd:** Banner alone is insufficient to establish the specially backdoored build associated with CVE-2011-2523; Ubuntu package evidence was marked not affected.
- **ProFTPD:** Potential CVE conditions depend on module/configuration prerequisites not established.
- **Tomcat/AJP:** Legacy connector exposure is confirmed; the reviewed Ghostcat claim was not applicable on available evidence.
- **WebDAV:** DAV configuration and a writable backing-directory observation are retained as a configuration-risk lead. No state-changing DAV request was made.
- **distccd, Ruby DRb and unknown high TCP ports:** Service-discovery leads only. No exploitability claim is made from port state or banner alone.

9. Risk assessment and prioritisation

Likelihood and impact are scored from 1 to 5. Risk score equals likelihood multiplied by impact.

Score band	Rating
1–4	Low
5–9	Moderate
10–16	High
17–25	Critical

This is a qualitative model, not CVSS. Ratings are contextual to the observed lab configuration and provisional for HanTech because production asset criticality, data classification, exposure, business dependencies and compensating controls have not been supplied.

Finding	Likelihood	Impact	Score	Rating	Treatment priority
F-01 NFS wildcard root export	4	5	20	Critical	Immediate
F-02 Anonymous SMB enumeration	4	2	8	Moderate	Planned
F-03 HTTP configuration resource	4	4	16	High	Urgent
F-04 Public credential disclosure	4	4	16	High	Urgent
F-05 Telnet/r-services	3	4	12	High	Urgent

Risk order: F-01, F-03/F-04, F-05, then F-02. A score does not mean potential impact was observed. Actual HanTech residual risk must be recalculated using business context and verified controls. No risk acceptance is claimed.

10. Security controls and recommendations

Controls are proposed designs, not proof of implementation.

Finding / area	Preventive	Detective	Corrective / recovery	Closure evidence
F-01 NFS	Remove root export; explicit client allowlist; root_squash; read-only data exports; firewall RPC/NFS	Export review; NFS logs; alert on wildcard exports	Revoke unsafe export; restore trusted files if required	Approved exports config; ACL/firewall evidence; post-change export output
F-02 SMB	Disable guest/null-session enumeration; per-share ACLs; segment SMB	Guest-logon and share-enumeration monitoring	Revoke anonymous permissions; restore ACLs	Sanitised config/ACLs; authorised denial retest; logs
F-03 Web configuration	Move config outside web root; deny sensitive paths; secret manager; filesystem ACLs	Web access log monitoring; secret scanning	Remove exposure; rotate confirmed exposed secrets; review logs	Deny response; document-root/permission evidence; scan report
F-04 Credentials	Remove public credential strings; disable defaults; unique secrets; MFA	Content scanning; default-account review; authentication alerts	Rotate/revoke secrets; investigate suspicious access	Updated page; account policy and rotation evidence; alert sample
F-05 Remote services	Disable Telnet/r-services; hardened SSH; MFA; management allowlist	Listener inventory; drift detection; authentication logs	Terminate obsolete listeners; revoke trust files/accounts	Listener scan; service config; SSH/MFA evidence
Legacy stack	Migrate to supported OS/runtime; remove demo apps/modules	Asset inventory; patch-age and vulnerability monitoring	Patch/migrate; isolate until replacement	Supported version inventory; change record; retest
WebDAV/AJP leads	Disable if unused; restrict methods/connectors	Configuration and listener reviews	Close unnecessary services and restore hardened settings	Effective config and authorised post-change checks

Cross-cutting programme: asset ownership; secure configuration baselines and change control; risk-based vulnerability/patch management; least privilege and MFA; data classification and encryption; central logging and incident response; protected backups and restore tests; supplier/cloud governance; security awareness; evidence-backed remediation closure.

A control is closed only after an approved change, configuration evidence, safe validation, monitoring evidence where relevant, a timestamped record and accountable residual-risk disposition.

11. GRC policy framework

The GRC workstream contains five policy drafts for the fictional HanTech organisation. They are proposed policy requirements, not adopted corporate policies.

Policy ID	Policy	Proposed accountable role	Purpose
POL-01	Vulnerability, Patch and Secure Configuration Management	Head of IT / Security Lead	Asset inventory, supported software, patch SLAs, exceptions and secure baselines
POL-02	Identity, Authentication and Credential Management	Head of IT / IAM Owner	Unique identities, MFA, least privilege, secret lifecycle and privileged access
POL-03	Network Security and Remote Access	Network Security Lead	Segmentation, firewall rules, approved remote access and service exposure
POL-04	Data Classification, Secure Application Configuration and Secrets	Data Owner / Application Owner	Classification, secure configuration, web-root protection, encryption and secrets
POL-05	Security Logging, Incident Response and Recovery	Security Lead / Incident Response Owner	Logging, detection, evidence preservation, response, backups and recovery

Governance requirements: name policy owners and approval authority; review at least annually and after material incidents/regulatory changes; document exceptions with justification, compensating controls, expiry and approval; communicate policies to staff/suppliers; retain implementation, training, exception and review evidence.

Conditional legal and standards applicability

- **Nigeria Data Protection Act 2023:** assess where HanTech processes personal data as a controller or processor within the Act's scope. Confirm roles, data categories, purposes, contracts, transfers and applicable NDPC instruments.
- **GDPR:** applies only where territorial-scope conditions are met, such as EU establishment or offering services to/monitoring people in the EU.
- **HIPAA:** applies only if HanTech is a covered entity or business associate handling electronic protected health information.
- **PCI DSS v4.0.1:** applies where payment-card data is stored, processed or transmitted, or systems can affect the cardholder data environment.
- **NIST CSF 2.0 and CIS Controls v8.1:** risk-management and safeguard-alignment references; not laws merely because they are cited.
- **NIST SP 800-53 Rev. 5 and ISO/IEC 27001:2022:** use where selected by management, contract or assignment requirements; do not claim certification or formal conformity without assessed scope and evidence.

The project does not assert that HanTech processes health/payment-card data, has an EU establishment or operates a particular cloud provider.

12. Cloud security assessment

12.1 Status

Task 7 is completed as a desk-based cloud-security baseline and evidence plan. No cloud provider, tenant, subscription/account, project, region, architecture, workload or authorised read-only identity was supplied. No live cloud configuration assessment or penetration test was performed.

12.2 Shared responsibility

Model	Provider generally manages	Customer generally manages
IaaS	Facilities, hardware, network fabric and hypervisor	Guest OS, patching, workloads, virtual network rules, IAM, data, encryption configuration and backups
PaaS	Infrastructure, host OS, platform/runtime and managed-service operation	Application code, data, identities, permissions, secrets, service configuration and logging
SaaS	Infrastructure and application operation	Data governance, user identities, MFA, roles, sharing, endpoint security, integrations and retention

Exact responsibility boundaries must be checked against the selected provider and service.

12.3 Cloud control baseline

- Central identity, MFA and least-privilege roles; time-bound privileged elevation.
- Private network paths for sensitive workloads; deny inbound by default and restrict management access.
- Data inventory/classification, encryption at rest/in transit, managed keys and secret stores.
- Protected audit logs for identity, control-plane, network, storage, database and application activity.
- Encrypted and access-separated backups with tested restoration.
- Secure CI/CD, dependency and secret scanning, signed artefacts and software-bill-of-materials provenance.
- Supplier assurance, data residency, processor terms and exit planning.
- Incident playbooks covering account compromise, key revocation, evidence preservation, isolation and recovery.

12.4 Evidence required before live review

Obtain written authorisation and identify provider, tenant/account/project, region, assets, service models, authorised role and rules of engagement. Collect redacted IAM/MFA exports, network rules, encryption/key settings, audit logs, backup evidence, vulnerability reports, data flows and provider responsibility documents. Start with read-only inspection. Do not probe a tenant without explicit scope.

Cloud conclusion: No cloud misconfiguration can be confirmed from the supplied information. The desk-based baseline is complete; live assessment remains not started because no authorised environment was supplied.

13. Prioritised implementation roadmap

Priority	Action	Proposed accountable role	Completion evidence
Immediate	Remove wildcard writable NFS root export and restrict NFS	Infrastructure/Linux owner	Approved config, export review and safe retest
Immediate	Remove web-accessible configuration resource and review exposure	Application/Web owner	Deny response, permissions, log review and secret scan
Immediate	Remove public credential disclosure; rotate/disable default account through change control	IAM/Application owner	Updated page, account record and rotation evidence
High	Disable Telnet and Berkeley r-services; migrate to hardened SSH	Infrastructure/Network owner	Closed listener inventory and SSH configuration
Medium	Disable anonymous SMB enumeration and apply share ACLs	File services owner	Share ACLs and authorised denial retest
Strategic	Upgrade unsupported OS, Apache, PHP, Tomcat and other legacy services	IT/Application owners	Supported asset inventory, patch records and retest
Strategic	Implement central logging, access reviews, backup testing and policy governance	Security/IT management	Logs, review records, restore test and approved policies
Before cloud deployment	Establish provider, tenant, service ownership and shared-responsibility controls	Cloud service owner	Written scope, architecture, IAM and baseline evidence

The project task allocations are Jeffrey (Tasks 1–2), Bonaventure (Tasks 3 and 8), Abundance (Task 4), Adeayo (Task 5) and Amos Talks (Task 6). Operational HanTech remediation owners are proposed roles because no real HanTech staff directory or accountable production owners were supplied.

14. Limitations and residual uncertainties

1. Only Metasploitable 2 at 192.168.138.20 was assessed as an authorised target.
2. The second system mentioned in the project theme was not identified in the available scope record; no substitute target was invented.
3. UDP coverage was top-100 only, not a full UDP-port scan.
4. Three UDP ports were open|filtered/no-response and are not confirmed open.
5. Four high TCP ports were open but not identified.
6. No exploitation, brute force, credential submission, NFS mount, SMB file-content access, application login, database query or target mutation occurred.
7. Samba CVE-2007-2447 remains a candidate pending installed-binary patch provenance.
8. Other legacy service/package observations do not establish CVE applicability by banner alone.
9. Risk ratings are lab-context estimates; HanTech business context and residual-risk acceptance are unknown.
10. No live HanTech production or cloud environment was supplied.
11. GRC policies and security controls are proposed designs; adoption and implementation evidence do not exist in the supplied project material.

12. Assigned names are reproduced from the task-allocation record; no signatures or independent personal approvals are fabricated.

15. Conclusion

The project has completed authorised lab discovery, evidence-backed technical review, five-finding selection, risk prioritisation, control design, GRC policy drafting and the desk-based cloud-security baseline. The evidence shows unsafe NFS configuration, anonymous SMB enumeration, a web-accessible configuration resource, public credential disclosure and legacy remote services.

The highest priority is the wildcard writable NFS root export, followed by the web configuration exposure and public credential disclosure. Legacy remote administration should be removed, and anonymous SMB access should be restricted. These recommendations must be implemented and retested in a separately authorised environment before remediation can be described as complete.

The work demonstrates a traceable path from discovery to risk and governance. It does not claim that HanTech production has been tested, vulnerabilities exploited, policies adopted or controls implemented. Production risk decisions require actual HanTech asset, data, architecture and control evidence.

16. References

1. NIST, Cybersecurity Framework (CSF) 2.0: https://www.nist.gov/cyberframework
2. NIST SP 800-30 Rev. 1, Guide for Conducting Risk Assessments: https://csrc.nist.gov/pubs/sp/800/30/r1/final
3. NIST SP 800-53 Rev. 5, Security and Privacy Controls: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
4. CIS Critical Security Controls v8.1: https://www.cisecurity.org/controls/v8-1
5. OWASP Application Security Verification Standard: https://asvs.owasp.org/
6. Linux exports(5) manual: https://man7.org/linux/man-pages/man5/exports.5.html
7. Samba CVE-2007-2447 advisory: https://www.samba.org/samba/security/CVE-2007-2447.html
8. Ubuntu CVE-2007-2447 status: https://ubuntu.com/security/CVE-2007-2447
9. Nigeria Data Protection Act 2023: https://ndpc.gov.ng/wp-content/uploads/2024/03/Nigeria_Data_Protection_Act_2023.pdf
10. GDPR Article 3 — Territorial Scope: https://eur-lex.europa.eu/eli/reg/2016/679/oj
11. HHS, HIPAA Covered Entities: https://www.hhs.gov/hipaa/for-professionals/covered-entities/index.html
12. PCI Security Standards Council, Document Library: https://www.pcisecuritystandards.org/document_library/
13. AWS Shared Responsibility Model: https://aws.amazon.com/compliance/shared-responsibility-model/
14. Microsoft Azure Shared Responsibility: https://learn.microsoft.com/en-ca/azure/security/fundamentals/shared-responsibility
15. Google Cloud Shared Responsibility: https://docs.cloud.google.com/architecture/framework/security/shared-responsibility-shared-fate

Appendix A — Primary evidence locations

- Full TCP discovery and receipt: `09_Evidence\02_System_Discovery\01_Full_TCP_Discovery_20261108`
- Targeted TCP recheck and 9 November screenshots: `09_Evidence\02_System_Discovery\02_Targeted_TCP_Recheck_20261109`
- UDP top-100 native outputs, receipt and screenshots: `09_Evidence\02_System_Discovery\03_UDP_Top100_20261109`
- Network configuration and target reachability: `09_Evidence\01_Network_Configuration`
- Service configuration validation: `09_Evidence\03_Vulnerability_Assessment\01_Raw_Research_and_Validation\CAPSTONE138_SERVICE_CONFIGURATION_VALIDATION_20261108.txt`
- Mutillidae HTTP validation: `09_Evidence\03_Vulnerability_Assessment\01_Raw_Research_and_Validation\CAPSTONE138_WEB_APPLICATION_CONFIGURATION_AND_SENSITIVE_FILE_REVIEW_`
- Telnet/r-services review: `09_Evidence\03_Vulnerability_Assessment\01_Raw_Research_and_Validation\CAPSTONE138_TELNET_RSH_SERVICE_EXPOSURE_REVIEW_20261108.txt`
- Finding reconciliation and crosswalk: `04_Vulnerability_Assessment\CAPSTONE138_FINDING_AND_RISK_RECONCILIATION_20261109.md` and `FINDING_EVIDENCE_RISK_CROSSWALK_20261109.csv`
- Evidence distribution provenance: `09_Evidence\06_Integrity_and_Transfer\03_Transfer_and_Provenance`
- Active SHA-256 manifest and sidecar: `09_Evidence\06_Integrity_and_Transfer\01_Manifests`

Appendix B — Evidence integrity note

The pre-reorganisation manifest is a historical checkpoint and is superseded for the current folder structure. A new manifest is refreshed after the final folder and document updates. The active manifest and checksum sidecar are retained in `09_Evidence\06_Integrity_and_Transfer\01_Manifests`. An independent rehash must return zero missing files and zero mismatches. A hash match proves byte-level integrity relative to the manifest, not the correctness of a finding or completion of remediation.